

■■ HUMAN FIREWALL PLATFORM

MASTER PRODUCT SINGLE SOURCE OF TRUTH & PITCHING KITAB

Versi: 2.0 (Production & Investment Ready)

Tanggal: 30 Juli 2026

Klasifikasi: Dokumen Strategis Produk, Arsitektur, & Bisnis

1. RINGKASAN EKSEKUTIF & VALUE PROPOSITION

Human Firewall Platform adalah solusi *Human Risk Management (HRM)* terpadu generasi baru yang mengubah elemen manusia dari celah keamanan paling rentan (*weakest link*) menjadi **sensor telemetri ancaman terdepan (*first line of defense*)**.

■ Statement Nilai Utama (One-Liner):

"Mengubah perilaku risiko siber karyawan menjadi telemetri ancaman real-time yang terukur dalam nilai efisiensi finansial perusahaan (ALE/SLE Risk Reduction)."

■ 4 Keunggulan Utama Ekosistem:

1. **Chat-First Threat Reporting:** Pelaporan ancaman instan < 30 detik melalui Telegram / MS Teams / Slack Bot.
2. **Automated Multi-Engine Triaging:** Analisis ancaman otomatis biner mentah & URL via VirusTotal v3 & urlscan.io.
3. **Adaptive Gamification & Daily Quiz:** Poin reputasi, *daily streak recovery*, dan pembukaan lencana dinamis (**Sentinel, Guardian, First Report, Streak Master**).
4. **Executive Financial ROI Calculator:** Kuantifikasi risiko finansial otomatis dalam mata uang Rupiah berbasis formula ALE, SLE, dan ARO standar industri.

2. ANALISIS AKAR MASALAH (THE MARKET PAIN POINT)

A. Realita Industri Siber Saat Ini

- **85%+ Kebocoran Data Berasal dari Manusia:** Firewall, IPS, dan EDR terbukti tidak mampu mencegah manipulasi psikologis (*Social Engineering*) dan phishing tingkat tinggi.

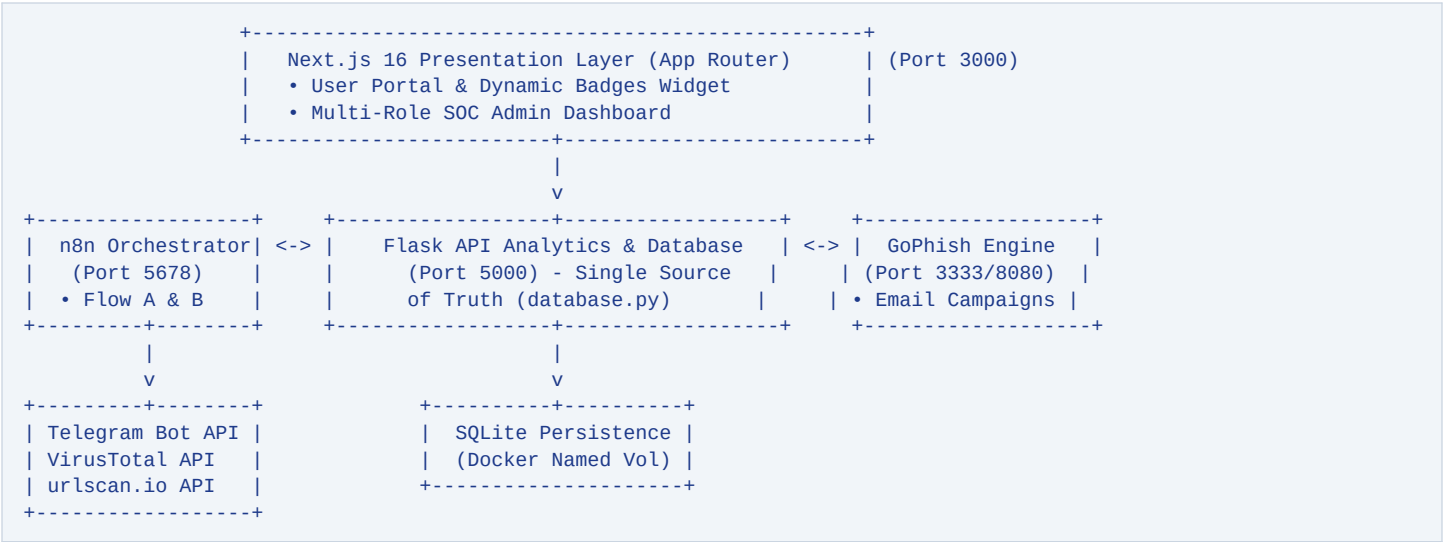
- **Karyawan Membenci Training Tradisional:** Video pelatihan 45 menit sekali setahun terbukti tidak efektif dan diabaikan oleh karyawan.
- **Proses Pelaporan Ancaman Lambat:** Ketika karyawan menemukan email/file mencurigakan, mereka tidak tahu harus melapor ke mana, atau antrean tiket SOC membutuhkan waktu berjam-jam untuk ditriase.

B. Celah Utama (The Strategic Blind Spot)

Alat SIEM (Splunk, Elastic, Wazuh) memiliki log dari firewall dan server, tetapi **TIDAK MEMILIKI DATA TELEMETRI PERILAKU MANUSIA**. Tim CISO dan GRC kesulitan membuktikan *Return on Investment (ROI)* dari program keamanan siber mereka kepada jajaran Direksi/CFO.

3. ARSITEKTUR TEKNIS EKOSISTEM (TECHNICAL ARCHITECTURE)

Platform dibangun di atas arsitektur **4-Layer Modular Stack** yang terisolasi dan *scalable* menggunakan Docker Compose:



■ Spesifikasi Modul:

- **Presentation Layer (Next.js 16.2):** Menggunakan TailwindCSS, Lucide Icons, Recharts, dan Polling Custom Hooks untuk performa real-time tanpa *overhead* WebSocket.
- **Business & Analytics Layer (Flask 3.x):** Memegang *Single Source of Truth* melalui **database.py**. Mengelola perhitungan poin, re-klasifikasi badge, dan penyediaan API endpoints.
- **Orchestration Layer (n8n 2.26):** Menangani *workflow logic* untuk penerimaan webhook Telegram Bot, pengunduhan biner bervolume tinggi, kuota API VirusTotal, dan notifikasi SOC.
- **Simulation Layer (GoPhish Engine):** Menangani pengiriman email simulasi massal dan penangkapan data *landing page*.

4. TIGA PILAR ALUR KERJA (CORE PRODUCT FLOWS)

■ Flow A: Adaptive Phishing Simulation & Retraining

1. Admin meluncurkan kampanye phishing dari Admin Dashboard (GoPhish).
2. Karyawan yang mengklik link / memasukkan data otomatis terdeteksi.

3. Backend meng-update **click_count**, meng-clamp poin minimum, dan secara otomatis mengarahkan karyawan ke **Modul Retraining Tier 1 atau Tier 2**.
4. Penyelesaian retraining mengembalikan sebagian poin reputasi karyawan.

■ Flow B: Incident Response & Threat Triaging (Telegram Bot)

1. Karyawan menemukan URL atau file mencurigakan dan mengirimkannya ke Telegram Bot.
2. Workflow n8n mengunduh biner mentah / memindai URL via VirusTotal API v3 & urlscan.io API.
3. **Laporan Safe:** Karyawan mendapat balasan konfirmasi aman.
4. **Laporan Malicious:** Karyawan mendapat **+15 Poin Reputasi**, tiket insiden baru dibuat di SOC Dashboard, dan notifikasi bahaya dikirim ke grup obrolan SOC Telegram.

■ Flow C: Gamification, Daily Quiz, & Unified Activity Feed

1. Karyawan mengakses kuis kesadaran harian (1 soal per hari) untuk menambah poin (+10 pts) dan memulihkan *daily streak*.
2. Memenangkan mini-game *Spot the Fake* memberikan +5 pts.
3. Kueri **SQL UNION ALL** menggabungkan tabel **events**, **threat_reports**, dan **daily_events** menjadi satu **Unified Activity Feed** kronologis pada Dashboard Pengguna.

5. MODEL KUANTIFIKASI RISIKO FINANSIAL (ALE / SLE / ARO)

Untuk memberikan nilai bisnis kepada CISO dan GRC, platform mengimplementasikan formulasi **Financial Risk Quantification**:

■ Rumus Dasar:

1. Single Loss Expectancy (SLE):

$$\text{SLE} = \text{Asset Value} \times \text{Exposure Factor (EF)}$$

(Estimasi biaya rata-rata kerugian 1x insiden kebocoran data = Rp 15.000.000,-)

2. Annualized Rate of Occurrence (ARO):

$$\text{ARO} = \text{Jumlah Klik Phishing Bulanan} \times 12$$

3. Annualized Loss Expectancy (ALE):

$$\text{ALE} = \text{SLE} \times \text{ARO}$$

■ Kalkulasi Penghematan (Cost Savings / Cyber ROI):

$$\text{Cost Savings (IDR)} = \text{ALE}_{\text{Sebelum Human Firewall}} - \text{ALE}_{\text{Terkini}}$$

Studi Kasus Perusahaan 1.000 Karyawan:

* **ALE Sebelum Training:** Rp 450.000.000,- / tahun (30 insiden/tahun).

* **ALE Setelah Training:** Rp 60.000.000,- / tahun (4 insiden/tahun).

* Total Penghematan Risiko Finansial (ROI): Rp 390.000.000,- / tahun!

6. ANALISIS PASAR & SKEMA BISNIS (TAM / SAM / SOM & B2B SAAS)

Potensi Pasar

- **TAM (Total Addressable Market):** Pasar Security Awareness Global = **\$2.1B (2023) → \$8.5B (2030)**.
- **SAM (Serviceable Available Market):** Perusahaan Terregulasi di Indonesia & Southeast Asia (Perbankan, Fintech, BUMN, Telco, E-Commerce) = **~12.000 Perusahaan**.
- **SOM (Serviceable Obtainable Market):** Target Klien Tahun ke-1 s.d ke-3 = **150 Enterprise & Mid-Market Clients**.

Model Pendapatan (B2B SaaS Pricing)

- **Tier Enterprise (Per-User Per-Month / PUPM):**
- **Standard Plan:** \$1.50 / user / bulan (Rp 22.500,-).
- **Enterprise All-in-One Plan:** \$2.50 / user / bulan (Termasuk Custom Bot, Premium Threat Intel, & SIEM Export).
- **Estimasi ARR (Annual Recurring Revenue):** 50 Klien $\times$ 1.000 User $\times$ \$2 = **\$1.200.000 / tahun (~Rp 18 Miliar/tahun)**.

7. MATRIKS KOMPETITOR & UNFAIR ADVANTAGES (USP)

Fitur / Kapabilitas	KnowBe4	Hoxhunt	Proofpoint	Human Firewall Platform
Primary User Interface	Email Add-in	Email Add-in	Email Add-in	Chat-First (Telegram/Teams) + Web
Instant Threat Triaging	Manual Queue	Email Scoring	Manual Queue	Real-Time Automated (<30s)
Multi-Engine Scanning	Tidak Ada	Terbatas	Tidak Ada	VirusTotal v3 + urlscan.io
Adaptive Gateway Policy	Tidak Ada	Tidak Ada	Tidak Ada	Auto-Block/Warn Risky Users
Gamification Engine	Static Points	Basic Emails	None	Daily Quiz, Streaks, & Dynamic Badges
Financial Risk Metric	Completion %	Click %	Completion %	ALE / SLE Financial Cost Savings (IDR)
Kepatuhan Lokal (UU PDP)	■ Tidak	■ Tidak	■ Tidak	■ 100% Sesuai Regulasi Indonesia

8. MATRIKS PERAN PENGGUNA (MULTI-ROLE WORKSPACES)

Untuk memikat berbagai *stakeholder* di perusahaan, platform membagi tampilan Admin menjadi **3 Perspective Workspaces**:

1. ■■ SOC Operations Workspace:

- Ditujukan untuk: Analis SOC & Incident Responder.
- Fitur: Tiket Insiden Live, Threat Intel Cache, & Konfigurasi Adaptive Gateway Policy Rules.

2. ■ Security Awareness Workspace:

- Ditujukan untuk: Phishing Admin & Security Training Officer.
- Fitur: GoPhish Campaign Launcher, Retraining Completion Tracker, & Employee Leaderboard.

3. ■ GRC & Executive Perspective:

- Ditujukan untuk: CISO, GRC Manager, & CFO/Board.
- Fitur: AI Executive Threat Summary, Compliance Score %, & Financial Risk ROI Calculator (ALE/SLE).

9. ANTISIPASI TANYA-JAWAB & DEFENSE PITCHING (Q&A; STRATEGY)

■ Q1: "Mengapa menggunakan Telegram Bot? Apakah aman untuk perusahaan?"

- **Jawaban Defense:** Telegram Bot digunakan pada tahapan MVP/Alpha karena kecepatan iterasi dan respon instant. Pada skenario implementasi *Enterprise*, arsitektur backend kami yang berbasis *Channel-Agnostic* mendukung koneksi langsung ke **Microsoft Teams Bot** dan **Slack Bot** via Webhook resmi perusahaan.

■ Q2: "Bagaimana menangani kuota limit API VirusTotal / urlscan.io?"

- **Jawaban Defense:** Sistem memiliki **Threat Intelligence Cache Layer** (tersimpan di SQLite/Redis). Jika ada 10 karyawan melaporkan URL/File yang sama, sistem hanya memanggil API eksternal 1 kali, dan 9 laporan berikutnya dijawab secara instant dari cache internal.

■ Q3: "Bagaimana jika karyawan secara sengaja spam laporan ke Telegram Bot demi poin?"

- **Jawaban Defense:** Sistem dilengkapi algoritma **Deduplication & Spam Throttling**. Laporan URL/File berulang dari user yang sama dalam rentang waktu singkat tidak akan menambahkan poin gamifikasi berulang (`counted_for_gamification = 0`).

Dokumen ini disusun sebagai *Single Source of Truth (SSOT)* resmi untuk *pitching investor*, *komersialisasi B2B SaaS*, dan dokumentasi *Capstone Design*.